KOMGIS

Model Provider Disclosure and Vendor / Subprocessor List

Governance, approval, disclosure and monitoring of third-party AI and cloud processing

Core provider governance commitment

KOMGIS will send client, confidential or personal data only to approved providers for a documented purpose. Provider terms, data use, retention, processing region, subprocessors and security controls must be reviewed before production use. A model or cloud provider is not an KOMGIS security or accountability boundary, and client data shall not be used for model training or unrelated service improvement without explicit, documented approval.

Document owner: AI Governance / Technical Leadership
Version: 1.0
Effective date: 8 July 2026
Classification: Internal Controlled Record

Document Control

Field	Value
Document title	KOMGIS Model Provider Disclosure and Vendor / Subprocessor List
Document owner	AI Governance / Technical Leadership
Version	1.0
Effective date	8 July 2026
Review frequency	At least annually and after defined trigger events; higher-risk providers may require more frequent reassessment
Approved by	[Executive approver / role]
Classification	Internal Controlled Record; client-facing extracts may be issued as approved disclosures
Applies to	AI model providers, cloud and hosting providers, subprocessors, vector/search services, observability vendors, integration providers and other third parties processing KOMGIS or client data
System of record	[Governance repository / register location]
Related policy	KOMGIS Responsible AI and AI Management Policy

Record Status and Use

This document is both a governance procedure and the specification for KOMGIS's controlled model-provider and vendor/subprocessor register. Provider-specific entries must be completed from current contracts, data-processing terms, service configuration and verified provider documentation. The presence of a provider name in a draft, sales proposal, technical experiment or software dependency does not constitute production approval.

The operational vendor list may be maintained in a controlled governance system, spreadsheet, database or service-management platform, provided the required fields and approval evidence defined in this document are preserved. A client-facing disclosure may contain a reduced set of fields, but the internal record shall remain sufficiently detailed to demonstrate why the provider is approved for the particular data and use case.

No invented approval rule

A provider shall not be presented as approved, active or used by KOMGIS unless the register identifies the applicable service, purpose, data categories, approval status and accountable owner. Placeholder records in the appendices are templates only.

Contents

1. Purpose
2. Scope
3. Governance Basis and Relationship to KOMGIS AI Policy
4. Definitions
5. Provider Governance Principles
6. Provider and Vendor Categories
7. Roles and Accountability
8. Provider Approval and Risk Tiering
9. Data Processing and Data-Flow Mapping
10. AI Model Provider Due Diligence
11. Training, Fine-Tuning and Service-Improvement Use
12. Retention, Deletion and Zero-Data-Retention Controls
13. Privacy, Confidentiality, International Transfers and Data Residency
14. Security, Enterprise Controls and Access
15. Subprocessor and Supply-Chain Governance
16. Cloud, Hosting, Storage and Managed Infrastructure
17. RAG, Embeddings, Vector, Search and Document Processing Providers
18. Agent Tools, Integrations and External-Action Vendors
19. Model Gateways, Observability, Evaluation and Logging Vendors
20. Contract, DPA and Client Requirements
21. Client Disclosure and Transparency
22. Provider, Product and Model Change Control
23. Ongoing Monitoring and Reassessment
24. Provider Incidents, Failures and Notifications
25. Exit, Termination, Portability and Provider Substitution
26. Vendor Register and Disclosure Record Management
27. Exceptions, Nonconformities and Corrective Action
28. Review and Enforcement
Appendix A. Provider Approval Tiers and Risk Matrix
Appendix B. Vendor / Subprocessor Master Register
Appendix C. Model Provider Disclosure Record
Appendix D. Provider Due Diligence Questionnaire
Appendix E. Provider Approval Checklist
Appendix F. Change and Reassessment Trigger Matrix
Appendix G. Client-Facing Subprocessor Disclosure Template
Appendix H. Minimum Evidence Pack and Record Retention

1. Purpose

This document defines how KOMGIS identifies, evaluates, approves, records, discloses, monitors, changes and retires third-party providers that process data or materially support an AI-enabled service. It is intended to ensure that provider selection does not weaken client confidentiality, tenant isolation, privacy, security, human accountability, traceability or contractual commitments.

The document establishes a controlled record for AI model providers and vendors/subprocessors and defines the minimum evidence that KOMGIS must obtain before sending client or confidential data to a third party. The level of review shall be proportionate to the provider's role, the sensitivity and scale of data, service criticality, system autonomy, affected persons and potential impact of provider failure.

- identify every third party that receives, stores, transmits, derives, logs or otherwise processes KOMGIS or client data for an AI system;
- document why the provider is needed and what exact service or model is approved;
- assess provider terms concerning training, service improvement, human review, retention and deletion;
- capture processing locations, data-residency constraints and relevant international transfers;
- review provider security, enterprise controls, incident processes and available contractual safeguards;
- maintain an accurate internal vendor/subprocessor register and approved client-facing disclosures;
- treat model, product, region and provider changes as controlled changes;
- maintain exit and substitution plans for providers whose failure could materially disrupt KOMGIS or a client.

2. Scope

This document applies to third parties used in KOMGIS internal AI systems, KOMGIS-operated services, client-specific deployments and AI-enabled software delivered or managed by KOMGIS. It applies during evaluation, proof of concept, development, testing, staging, production, support, incident response and retirement whenever real KOMGIS, personal, confidential or client data may be processed.

- generative AI and foundation-model APIs, hosted models and managed inference services;
- embedding, reranking, classification, transcription, speech, vision, OCR and document-understanding services;
- cloud infrastructure, managed compute, serverless services, databases, storage, queues, caches and managed Kubernetes services;
- vector databases, hybrid search, search-as-a-service and retrieval infrastructure;
- model gateways, routing services, prompt management, tracing, evaluation, observability and AI security services;
- identity, email, messaging, collaboration, CRM, ERP, ticketing and other tools callable by AI agents or workflows;
- external data enrichment, web search, crawling, geocoding or content services when they process client-linked data;
- consultants or managed-service providers with access to AI systems or production data where they act as processors or material service vendors.

Purely public information services that receive no KOMGIS or client data may be subject to a lighter review, but the technical owner must still confirm that the integration cannot inadvertently send prompts, identifiers, secrets, retrieved context, logs or other client-linked data.

3. Governance Basis and Relationship to KOMGIS AI Policy

This document supports the KOMGIS Responsible AI and AI Management Policy. The parent policy requires client or confidential data to be sent only to approved model providers and subprocessors, requires maintenance of a Model Provider Disclosure and Vendor/Subprocessor List, and treats a provider or model change as a controlled change. This document translates those requirements into operational approval, disclosure and recordkeeping controls.

It is informed by KOMGIS's management-system approach to AI governance and by privacy, security and contractual requirements applicable to the particular service. It does not by itself determine whether KOMGIS or a client is a

controller, processor, provider, deployer or other legally defined role, and it does not replace system-specific legal or compliance review.

Precedence

Where an executed client contract, DPA, security schedule, data-residency commitment or applicable law imposes a stricter requirement than this document, the stricter requirement applies to the affected service and shall be recorded in the provider approval record.

4. Definitions

Term	Meaning in this document
AI model provider	A third party providing a model, model API, hosted inference service or managed AI capability used by an KOMGIS AI system.
Vendor	A third party providing software, infrastructure, integration, support or another service used by KOMGIS.
Subprocessor	A third party engaged to process personal data on behalf of a processor or another processor in the processing chain, as assessed under applicable data-protection arrangements.
Provider service	The specific commercial product, API, endpoint, region or managed capability approved for use; approval of one service does not automatically approve every service from the same company.
Model family	A named group or series of related models offered by a provider.
Processing region	The location or region in which the provider states that covered data is processed or stored, subject to the actual service terms and configuration.
Training use	Use of submitted or derived data to train, fine-tune or otherwise improve provider or third-party models.
Service improvement	Provider use of data for product analytics, abuse monitoring, quality improvement or other purposes beyond direct request processing.
Zero data retention (ZDR)	A provider configuration or contractual arrangement intended to prevent covered content from being retained after request processing, subject to defined exceptions and verified scope.
Provider owner	The KOMGIS role accountable for the provider record, approval status, evidence and reassessment.
Inherent provider risk	Risk presented by the provider and intended processing before KOMGIS-specific controls are applied.
Residual provider risk	Risk remaining after contractual, configuration, architectural, monitoring and operational controls are applied.
Approved	The provider service is authorized for the explicitly recorded purpose, data, region and systems, subject to stated conditions.
Conditionally approved	The provider service may be used only under recorded restrictions, pilot scope, time limit or remediation conditions.
Blocked / prohibited	The provider service shall not receive covered data or be used for the stated purpose.

5. Provider Governance Principles

5.1 Purpose-specific approval

Approval is granted to a defined provider service for a defined use case. A company-level relationship does not automatically authorize every model, region, beta feature, connector or downstream service offered by that provider.

5.2 Data minimization before provider processing

KOMGIS shall send only the information necessary for the approved task. Where the task can be completed with selected records, retrieved chunks, masked identifiers, structured fields or limited excerpts, the full document library, database or conversation history shall not be sent.

5.3 No model-based trust boundary

Provider models shall not determine KOMGIS authorization, tenant identity, data residency, approval requirements or the permitted scope of tools. These controls shall be enforced by KOMGIS application and infrastructure logic.

5.4 Least provider exposure

Where equivalent business objectives can be met with lower provider exposure, KOMGIS should prefer designs that reduce the categories, volume, sensitivity and retention of data processed by the third party.

5.5 Verify terms and configuration

Marketing statements are not sufficient approval evidence. KOMGIS shall review the terms, documentation and technical configuration that actually apply to the chosen service, commercial plan, API, deployment method and region.

5.6 Client isolation remains KOMGIS responsibility

A provider's enterprise security features do not replace KOMGIS client and object authorization. KOMGIS shall enforce tenant scoping, retrieval filters, service-account boundaries and client-specific credentials where required before provider processing occurs.

5.7 Change awareness

Provider terms, model versions, default retention, subprocessors, regions and security capabilities may change. KOMGIS shall maintain change monitoring proportionate to risk and shall not assume that a prior review remains valid indefinitely.

6. Provider and Vendor Categories

Category	Typical services	Primary governance concern
AI model / inference provider	LLM, SLM, multimodal, speech, image, OCR, classification or managed model API	Prompt and content use; model training terms; retention; model changes; safety and quality; regional processing.
Cloud / hosting provider	Compute, serverless, containers, managed AI, networking	Data residency; privileged access; encryption; availability; subservices; account configuration.
Database / storage provider	SQL, NoSQL, object storage, managed files, caches	Data location; backup copies; encryption; deletion; tenant isolation; administrative access.
RAG / vector / search provider	Vector database, embeddings store, search or hybrid retrieval	Derived client data; metadata filters; deletion synchronization; cross-tenant retrieval risk.
Model gateway / AI platform	Routing, proxying, prompt management, model aggregation	Additional processing layer; logging; provider chaining; credential custody; hidden subprocessors.

Category	Typical services	Primary governance concern
Observability / evaluation provider	Tracing, prompt logs, evaluations, analytics	Full prompt/output capture; sensitive log retention; sampling; access; data export.
Agent tool / integration provider	Email, CRM, ERP, ticketing, calendar, file sharing	External write actions; OAuth scopes; client credential isolation; reversibility and approvals.
Content / data service	Web search, crawling, enrichment, geocoding, external datasets	Data sent in queries; licensing; provenance; personal-data exposure; third-party content risk.
Professional / managed service	Consultant, support provider, managed operations	Human access to production data; confidentiality; privileged access; support geography.

7. Roles and Accountability

Role	Minimum responsibilities
Executive leadership	Approve risk direction; review critical providers and unresolved high residual risk; support provider suspension or substitution when necessary.
AI Governance / Technical Leadership	Own the provider-governance method; approve risk tiering; review model providers; maintain governance evidence standards; coordinate reassessment and management review.
Provider owner	Maintain the provider record; verify approved use, evidence and conditions; track review dates and changes; ensure inaccurate disclosure is corrected.
AI system owner	Confirm business need and intended use; ensure the provider is approved for the system; accept residual business risk within authority; ensure client commitments are captured.
Technical owner	Document architecture and data flows; configure provider controls; restrict data sent; manage credentials; test integrations; implement rollback and substitution capability.
Security / privacy owner	Review data categories, provider security, access, logging, subprocessors, transfers, retention and DPA requirements.
Project manager / client owner	Capture client restrictions and approval requirements; coordinate client-facing disclosure and change notices; prevent use outside contracted scope.
Procurement / legal / compliance, where assigned	Review commercial terms, DPA, confidentiality, liability, notification, audit and transfer provisions as required by risk and contract.
Developers and operators	Use only approved provider services and credentials; do not enable unapproved beta features or copy client data into personal AI accounts; report provider anomalies or changes.

Named ownership required

Every production provider record shall identify a provider owner. Every production AI system shall independently identify a system owner and technical owner. Responsibility shall not be assigned solely to the third-party provider.

8. Provider Approval and Risk Tiering

A provider shall be approved before covered data is processed in production. Proof-of-concept use with synthetic or public data may be permitted before full approval, but the record must state that production client data is prohibited until the required review is complete.

8.1 Approval workflow

1. Identify the provider service, model or product and record the business and technical purpose.
2. Map the data that will be sent, generated, logged, stored or derived and identify affected clients or data subjects.
3. Assign a preliminary provider risk tier using Appendix A.
4. Complete the due-diligence fields and gather the evidence required for the tier.
5. Review provider terms for training, service improvement, retention, deletion, processing region and subprocessors.
6. Review security controls, credentials, administrative access, logging and available enterprise configurations.
7. Assess client contract, data residency, DPA and disclosure requirements.
8. Define architectural and operational controls that reduce provider exposure and residual risk.
9. Perform the required technical test or controlled pilot.
10. Record approval, conditions, residual risk, approvers and reassessment date before production use.

8.2 Approval statuses

Status	Meaning	Operational rule
Approved	Required review is complete and residual risk is accepted for the recorded use.	May be used only within the approved purpose, data categories, region, products and conditions.
Conditionally approved	Use is permitted with material restrictions, a time limit, pilot scope or open remediation.	Restrictions shall be technically and operationally enforced; expiry or condition dates must be tracked.
Pending review	Evidence or approval is incomplete.	No production client or confidential data shall be sent. Synthetic or public test data only unless separately authorized.
Suspended	Existing approval is temporarily withdrawn due to incident, provider change, control failure or reassessment.	Stop new processing; follow containment and migration instructions; system owner decides service handling with governance/security.
Blocked / prohibited	Provider or service is not authorized for the use case or data.	Do not connect, upload, prompt, log, route or otherwise send covered data to the service.
Retired	Provider is no longer used in active processing.	Credentials revoked; integrations disabled; exit and deletion evidence retained as required.

9. Data Processing and Data-Flow Mapping

The provider record shall be linked to the Data Processing Map for each material AI system. KOMGIS shall identify not only the visible user prompt but all data that may be exposed through retrieval, metadata, conversation state, attachments, tracing, debugging, tool execution or provider support processes.

9.1 Minimum data-flow questions

- What data leaves the KOMGIS-controlled boundary and by which protocol, API, SDK or managed integration?
- Is the provider receiving full source files, extracted text, chunks, metadata, embeddings, images, audio, structured records or only a minimized prompt?

- Are user identifiers, tenant identifiers, document names, source URLs, filenames, case numbers or business references included?
- Does a provider gateway, observability system or model router receive the same content before or after the model provider?
- Does the provider retain request or response content, abuse logs, safety logs, telemetry or support snapshots?
- Can provider personnel access content for support, abuse review or quality investigation?
- Where are primary data, replicas, caches, logs and backups processed or stored?
- Which downstream subprocessors or cloud services may process the covered data?
- What data is returned and what derived data is stored by KOMGIS after processing?
- How is deletion synchronized across source records, derived records and provider-side retention where applicable?

9.2 Data category record

Data category	Examples	Provider review expectation
Public / non-sensitive	Public website content, public manuals, published regulations	Confirm no hidden client metadata or credentials are attached.
Confidential business data	Contracts, internal procedures, financial or operational records	Enterprise terms and data-use review; minimize content; restrict logs and access.
Personal data	Names, emails, user accounts, customer records, communications	Privacy/DPA review; purpose and minimization; transfer and retention assessment.
Sensitive or regulated data	Health, employment, insurance, legal case data or other protected categories where applicable	Enhanced review; explicit client and legal requirements; stronger provider, region and access conditions.
Secrets / credentials	Passwords, API keys, access tokens, private keys	Prohibited from AI prompts or provider content. If exposure occurs, treat as an incident and rotate/revoke.
Derived AI data	Embeddings, vector metadata, summaries, classifications, extracted fields	Govern as client data when derived from client content; define retention and deletion linkage.
Audit / observability data	Prompt IDs, model version, tool calls, traces, snippets	Prefer metadata; avoid unnecessary content capture; restrict access and retention.

10. AI Model Provider Due Diligence

AI model providers require specific review because the service may infer from unstructured client content, produce non-deterministic outputs and change model behavior over time. The review shall address both data-processing risk and model/service risk.

10.1 Provider and service identity

- provider legal entity and contracting entity;
- commercial product, API, managed service or deployment type;
- approved model family and specific model identifiers where material;
- API endpoint or region used and whether the service is preview, beta, experimental or generally available;
- whether a reseller, model gateway, cloud marketplace or managed platform sits between KOMGIS and the model provider;
- support plan and enterprise control availability.

10.2 Data-use and content review

- whether provider terms permit submitted prompts, files, images, audio, outputs or metadata to be used for training or model improvement;
- whether opt-out, enterprise exclusion or API-specific terms apply and how KOMGIS verifies the effective setting;
- whether provider personnel may review content and for what purposes;
- whether content is retained for abuse, safety or operational monitoring and for how long;
- whether content can appear in provider dashboards, traces, playgrounds or support systems;
- whether provider-created embeddings, caches or batch files have separate retention rules.

10.3 Model behavior and lifecycle review

- model version stability and provider versioning policy;
- deprecation and retirement notification process;
- availability of pinned or dated model versions when reproducibility is required;
- documented context-window, modality, tool-use or structured-output limitations relevant to the system;
- rate limits, quotas, latency and regional availability that may affect safe workflow behavior;
- provider safety features that KOMGIS uses as supplemental controls, without treating them as the sole security boundary;
- known limitations or provider notices that materially affect KOMGIS evaluation criteria.

Model name is not enough

The disclosure record shall identify the actual service path and configuration. For example, a named model accessed through a cloud managed-AI platform may have different processing terms, regions, logging and subprocessors from the same model accessed directly from the model developer.

11. Training, Fine-Tuning and Service-Improvement Use

KOMGIS's default position is that client data shall not be used to train or fine-tune KOMGIS or third-party models unless the client explicitly approves the use and the purpose, data, legal or contractual requirements, retention and safeguards are documented. Provider review must separately assess direct model training and broader service-improvement uses.

11.1 Required record

Question	Required recorded answer
Can submitted content be used to train provider models?	Yes / No / Not applicable / Unclear. If no, identify the term, plan or configuration that provides the exclusion.
Can outputs be used for training or improvement?	Record separately from prompts and source files.
Can content be reviewed by humans?	Identify purpose, scope and any enterprise restriction or exception.
Does the provider use metadata or telemetry for service improvement?	Describe categories and whether client-linked identifiers are included.
Is an opt-out or enterprise setting required?	Record configuration owner, location, verification date and evidence.
Is KOMGIS fine-tuning a model?	Record the exact dataset, client approval, purpose, retention, deletion and model ownership.
Are provider safety/abuse logs retained under an exception?	Record the exception and its practical impact on client commitments.

11.2 Unclear terms

Where provider documentation is ambiguous about data use, KOMGIS shall not infer the more favorable position. The provider record shall remain pending or conditionally approved for non-sensitive test data until the uncertainty is resolved through authoritative terms, contractual clarification or a lower-exposure architecture.

12. Retention, Deletion and Zero-Data-Retention Controls

Provider retention shall be assessed for request content, response content, uploaded files, batch jobs, caches, safety or abuse logs, support records, observability data and backups. A single statement that a provider does not train on data is not evidence of zero retention.

12.1 Required retention fields

- default retention period for covered content;
- retention period under the exact enterprise or API plan used by KOMGIS;
- whether zero-data-retention or modified-abuse-monitoring controls are available and enabled;
- exceptions to ZDR, including product features that do not support it;
- separate retention for files, batch processing, fine-tuning datasets, cached prompts or provider dashboards;
- provider deletion method and whether deletion is automatic, API-driven, console-based or support-request based;
- backup or disaster-recovery retention where documented;
- evidence date and owner who verified the current configuration.

12.2 Architecture when provider deletion is limited

When a provider cannot meet the required deletion or retention objective, KOMGIS shall either select a different service, reduce the data sent, tokenize or pseudonymize identifiers where appropriate, avoid the provider for the affected workflow, or obtain explicit risk and client approval when legally and contractually permissible. Convenience or model quality alone is not sufficient reason to bypass a documented retention requirement.

13. Privacy, Confidentiality, International Transfers and Data Residency

Provider approval shall consider KOMGIS and client confidentiality requirements and, where personal data is processed, the applicable privacy and data-processing arrangement. The provider record must distinguish between contractual processing location, configurable service region, actual storage region and support or subprocessor access where these differ.

13.1 Data-residency review

- client-mandated country, EEA/EU or other regional restrictions;
- provider regions supported by the exact service and model;
- whether model inference, storage, logs and backups remain in the selected region;
- whether support or security operations may access data from another region;
- whether a provider may move processing during capacity or incident conditions;
- whether downstream subprocessors are bound to the same regional limitation;
- technical settings that select or lock the region and the person responsible for verifying them.

13.2 International transfer record

Where relevant, the provider record shall identify the assessed transfer mechanism, DPA or contractual basis and any client-specific transfer restrictions. Legal interpretation shall be escalated to qualified legal or privacy review. The vendor register should record the result and supporting document reference rather than contain speculative legal conclusions.

13.3 Confidentiality and support access

The review shall identify whether provider employees, contractors or support personnel may access client content; what authorization and audit controls apply; and whether KOMGIS can restrict or approve support access. Production-data access by KOMGIS personnel and third parties should be time-bound and logged where practical for sensitive services.

14. Security, Enterprise Controls and Access

Provider security review shall be proportionate to risk and should focus on controls that are relevant to the service KOMGIS actually uses. Certification or audit reports may support due diligence but do not replace architecture-specific review or correct configuration by KOMGIS.

14.1 Minimum security topics

Control area	Review expectations
Identity and administration	SSO/MFA where available; named administrators; least privilege; production access review; separate personal and company accounts.
API credentials	Secret storage; service-specific credentials; client or environment separation where needed; rotation; restricted scopes; no keys in prompts or source code.
Encryption	Transport encryption; storage encryption where data is retained; provider key-management options when required.
Tenant isolation	Provider tenancy model, project/workspace boundaries and KOMGIS-side client scoping; no reliance on model discretion.
Network controls	Private connectivity, egress allowlists, endpoint restrictions or IP controls where justified by risk and available.
Logging and audit	Administrative actions, credential changes, usage and security events; restrict sensitive content in logs.
Vulnerability and incident handling	Security contact, notification expectations, vulnerability handling and relevant status/incident information sources.
Resilience	Availability history or commitments, regional failover, rate limits, quotas, provider dependency and operational workarounds.
Secure development evidence	Provider security documentation, independent assurance reports or other evidence appropriate to risk and contractual availability.

14.2 Configuration is part of approval

An approved provider may become unsafe through incorrect configuration. The provider record shall identify material controls that KOMGIS must enable or preserve, such as data-retention settings, project isolation, SSO, regional endpoints, private networking, log redaction or disabled provider dashboards. These conditions shall be included in deployment checklists or infrastructure-as-code where practical.

15. Subprocessor and Supply-Chain Governance

KOMGIS shall identify relevant downstream providers when the primary provider uses subprocessors or material cloud infrastructure to deliver the service. The purpose is to understand the actual processing chain and to meet client, privacy and contractual disclosure obligations where applicable.

15.1 Subprocessor record requirements

- subprocessor name and function where disclosed by the primary provider;
- whether the subprocessor may process content, metadata, support data or only infrastructure telemetry;
- country or region information provided by the primary provider;
- source and date of the subprocessor list used for review;
- provider process for subprocessor additions or changes;
- KOMGIS client notification or objection obligations where contractually required;
- material concentration or single-supply-chain dependencies relevant to continuity.

15.2 Provider chaining

A model gateway, orchestration platform or managed AI service may itself be an KOMGIS vendor and may route requests to one or more model providers. KOMGIS shall record each material processing layer. Approval of the gateway does not automatically approve every downstream model destination, and provider routing shall be constrained to the approved allowlist for the active use case.

15.3 Subprocessor change response

When a material subprocessor change is identified, the provider owner shall determine whether the change affects processing region, data categories, security, client disclosure or risk acceptance. Required client notice or objection processes shall be coordinated before continued use where the contract requires this.

16. Cloud, Hosting, Storage and Managed Infrastructure

Cloud and infrastructure providers may process a broader volume of client data than the model provider because they host databases, files, logs, queues, vector stores and backups. Their review shall therefore cover the complete deployed architecture, not only the AI request path.

16.1 Cloud-specific approval controls

- approved account, organization, subscription and region structure;
- separation of development, test and production environments;
- identity and privileged-access controls, including emergency access;
- network ingress and egress boundaries and exposure of managed endpoints;
- storage encryption and key-management responsibilities;
- backup scope, replication and restoration processes;
- logging and audit service configuration and retention;
- managed AI, database, serverless and marketplace services that introduce additional processors;
- support-access and diagnostic data handling;
- service continuity, regional outage and account lockout considerations.

16.2 New managed service rule

Use of a new managed cloud service may introduce a new processing purpose or subprocessor even when the primary cloud provider is already approved. The technical owner shall assess whether the service materially changes data exposure, region, retention, administrative access or client commitments before enabling it in production.

17. RAG, Embeddings, Vector, Search and Document Processing Providers

RAG and document-intelligence providers may process source files, extracted text, document chunks, metadata, embeddings and search queries. Embeddings and vector records derived from client content shall be governed as client data when they encode or are linked to that content.

17.1 Required provider review

- whether source documents are uploaded to the provider or processed only inside KOMGIS infrastructure;
- whether the provider generates embeddings and which service receives the original text;
- vector storage region, backup behavior and deletion capabilities;
- metadata filtering, namespace, collection, project or tenant controls available for client isolation;
- ability to delete or disable vectors and chunks when the source document is deleted;
- provider logs that may contain query text, chunk text or filenames;
- administrative access to indexes, collections or search dashboards;
- hybrid search or reranking services that create an additional processing hop;
- limits on data export, bulk retrieval and cross-project credentials.

17.2 Permission enforcement

A vector or search provider shall not be relied upon to infer user permissions from document content. KOMGIS shall enforce tenant, user and object authorization through backend logic and provider-supported filters before retrieved content enters the model prompt. Broad retrieval followed by model-based hiding is prohibited.

17.3 Deletion linkage

The system design shall link source identifiers to extracted text, chunks, vectors and derived summaries so that deletion or disabling of the source can propagate to active derived records. Provider limitations or delayed deletion must be recorded in the data-processing and retention design.

18. Agent Tools, Integrations and External-Action Vendors

A vendor integrated as an AI agent tool may not receive the model prompt itself, but the tool can expose client records to the agent or allow the agent to take external actions. Such vendors shall be reviewed for both data-processing risk and action authority.

18.1 Integration-specific fields

Field	Required detail
Integration type	OAuth, API key, service account, webhook, plugin, MCP server, managed connector or other.
Read scopes	Exact objects and records the integration can retrieve.
Write scopes	Exact actions the integration can create, modify, send, approve, delete or share.
Credential ownership	KOMGIS-wide, client-specific, user-delegated or service-specific credential.
Client isolation	How credentials, tokens, workspace IDs and tool calls remain scoped to the active client.
Human approval	Sensitive actions that require a blocking approval before the provider call is executed.
Reversibility	Whether the action can be cancelled, rolled back or corrected.

Field	Required detail
Provider logs	Whether tool payloads or action content are logged by the vendor and for how long.
Failure behavior	Timeout, duplicate action, retry and idempotency behavior.

18.2 Sensitive action rule

Sending external communications, updating official client records, triggering payments, sharing files, submitting forms, deleting important records and other material or difficult-to-reverse actions require defined human approval unless a specific lawful automation use has been assessed and approved. Provider capabilities shall not bypass KOMGIS approval gates.

19. Model Gateways, Observability, Evaluation and Logging Vendors

AI middleware can create hidden copies of sensitive content. A model gateway, tracing platform or evaluation service may receive the full prompt, retrieved context, model output, tool calls and user identifiers. KOMGIS shall therefore treat these services as potential processors even when they are described as developer tooling.

19.1 Logging and tracing review

- whether full prompt and response content is captured by default;
- whether retrieved document chunks, citations or tool payloads are captured;
- sampling controls and ability to disable content logging for sensitive systems;
- redaction or masking capabilities and their limitations;
- data retention, export and deletion functions;
- project/workspace isolation and access roles;
- provider model-training or service-improvement terms for logged content;
- regions and subprocessors applicable to the logging product, which may differ from the model API;
- ability to use local or self-hosted evaluation for higher-sensitivity datasets.

19.2 Metadata-first logging

KOMGIS should prefer metadata over full content where operational objectives can be achieved without retaining prompts, documents or outputs. Full content logging shall be explicitly justified, restricted, retained for the minimum necessary period and linked to the Data Processing Map and retention schedule.

20. Contract, DPA and Client Requirements

Provider approval shall identify the contractual and data-processing terms that apply to the service. Free, personal, trial or click-through terms shall not be used for client confidential data unless expressly reviewed and approved for that purpose.

20.1 Contract review topics

- confidentiality and permitted use of customer content;
- data-processing roles and DPA availability where personal data is involved;
- provider rights concerning training, service improvement, analytics and human review;
- retention, deletion and return of data;
- security commitments and available assurance evidence;
- subprocessor engagement and change process;
- incident or breach notification commitments;

- international transfer and data-residency provisions;
- service suspension, deprecation, termination and export rights;
- audit, information or cooperation rights where required by client or law;
- liability and risk allocation for material services, escalated according to KOMGIS authority rules.

20.2 Client-specific restrictions

The vendor register shall be capable of recording client-specific restrictions. A provider may be generally approved by KOMGIS but prohibited for a particular client because of data residency, sector rules, contractual terms, named-provider restrictions or a client approval requirement. Technical architecture and deployment configuration shall enforce these restrictions where feasible.

21. Client Disclosure and Transparency

KOMGIS shall provide information about model providers and subprocessors when required by contract, privacy arrangements, law or the agreed service-transparency model. Client-facing disclosures shall be accurate, understandable and limited to the providers relevant to the client's service.

21.1 Minimum client-facing disclosure fields

Field	Client-facing content
Provider / subprocessor	Legal or commonly recognized provider name.
Service role	For example AI inference, cloud hosting, managed database, vector search, email delivery or monitoring.
Processing purpose	Plain-language description of why the provider is used in the client service.
Data categories	High-level categories of client or personal data processed. Avoid exposing secrets or unnecessary architecture details.
Processing location / region	The region or location information KOMGIS is contractually and technically able to disclose.
Training position	Where relevant, KOMGIS's approved position on use of client content for model training, subject to actual provider terms and configuration.
Status / effective date	Active or planned service and date from which the disclosure applies.
Change notice route	How material provider or subprocessor changes are communicated when required.

21.2 Internal details not normally published

Internal risk scores, credential architecture, vulnerability information, non-public security findings, detailed fallback procedures and sensitive network information should not be included in a public provider list unless disclosure is specifically approved. These details remain available for controlled client security review where appropriate.

21.3 Accuracy of provider claims

KOMGIS shall not state that a provider offers zero retention, EU-only processing, no training or another material protection unless the provider record identifies the applicable service terms and configuration. Client disclosures must be updated when KOMGIS learns that a material statement is no longer accurate.

22. Provider, Product and Model Change Control

A provider or model change is a controlled AI system change. The technical owner and provider owner shall assess the change before production use when it may affect data processing, model behavior, security, client disclosure or system risk.

22.1 Material provider changes

- adding a new model provider or cloud processing service;
- changing from direct provider access to a gateway, managed platform or reseller;
- changing the provider legal entity, contracting entity or applicable service terms;
- moving to a new processing region or enabling cross-region failover;
- enabling a feature with different retention or training terms, including files, batch jobs, fine-tuning or provider dashboards;
- adding a materially new subprocessor or processing location;
- changing from a pinned model version to an automatically updated model alias;
- introducing a model family with materially different capabilities, modalities or tool-use behavior;
- enabling content logging, tracing or observability through a new vendor;
- adding an agent integration with write permissions or broader OAuth scopes.

22.2 Required change review

Material changes shall trigger review of the AI System Inventory, Data Processing Map, provider/vendor record, risk assessment, retention settings, client requirements, evaluation evidence, security controls, monitoring plan and disclosure obligations as applicable. The change record shall identify the previous and new provider configuration and the effective release date.

22.3 Emergency provider substitution

A service outage does not automatically authorize routing client data to an unapproved model or region. Emergency substitution must use a pre-approved fallback or follow an expedited risk and approval process proportionate to the incident. Any temporary deviation shall be documented and reviewed after service restoration.

23. Ongoing Monitoring and Reassessment

Provider approval is not permanent. KOMGIS shall reassess providers according to risk and when trigger events occur. Monitoring may use provider notices, contract contacts, status information, security advisories, subprocessor updates, service documentation, client feedback and KOMGIS operational evidence.

23.1 Monitoring topics

- changes to data-use, training or service-improvement terms;
- changes to default or enterprise retention controls;
- new or changed subprocessors and processing locations;
- security incidents, material vulnerabilities or control limitations relevant to KOMGIS use;
- model deprecations, new default aliases or material behavior changes;
- outages, quota changes, rate-limit changes or recurring service instability;
- client complaints or security-review concerns linked to the provider;
- unexpected provider content logging, support access or data exposure identified through testing;
- changes to KOMGIS data categories, volume, autonomy or reliance that increase provider risk.

23.2 Reassessment cadence

Provider tier	Minimum review expectation
Tier 1 - Critical / high exposure	At least annually and after any material trigger; more frequent control checks may be required for retention, regional configuration or client-specific conditions.
Tier 2 - Material processor	At least annually or according to the approved governance schedule; review material provider notices and changes.
Tier 3 - Limited exposure	Periodic review proportionate to use; immediate reassessment if the service begins processing client or personal data.
Conditionally approved	Review by the recorded condition or expiry date; no automatic extension without evidence.

24. Provider Incidents, Failures and Notifications

A provider-related event may be an AI incident, security incident, privacy incident, service-continuity issue or contractual nonconformity. KOMGIS shall follow the AI Incident Response Plan and other applicable incident processes based on the actual impact.

24.1 Provider incident examples

- provider exposure or suspected exposure of client prompts, files, outputs or logs;
- incorrect processing region or loss of required data-residency control;
- provider use of client content contrary to the approved training or service-improvement position;
- unexpected provider logging or retention discovered after deployment;
- material subprocessor change without required KOMGIS or client action;
- model behavior change causing unsafe, materially wrong or unsupported outputs;
- provider outage causing approval bypass, duplicate actions or unsafe fallback behavior;
- compromise of provider API credentials or administrative access;
- provider deprecation or suspension that creates material service or data-access risk.

24.2 Immediate response

1. Stop or limit affected processing when continued use may increase impact.
2. Disable the affected provider route, model, feature or integration where necessary.
3. Preserve provider notices, logs, request IDs, configuration evidence and relevant KOMGIS records.
4. Identify affected systems, clients, data categories, regions, prompts, files or tool actions.
5. Rotate or revoke credentials if compromise is suspected.
6. Coordinate with the provider through the approved security or support channel.
7. Assess client, legal, privacy, contractual and regulatory notification requirements.
8. Implement corrective controls or approved substitution and retest before normal processing resumes.
9. Update the provider record, risk assessment, monitoring and evidence pack.

25. Exit, Termination, Portability and Provider Substitution

KOMGIS shall plan for provider exit when the service is critical, processes significant client data or creates material operational dependency. The exit plan shall be proportionate to the cost and risk of provider failure, termination or strategic replacement.

25.1 Exit considerations

- ability to export configuration, data, vector records, prompts, evaluations or other required artifacts;
- model-provider substitution and required re-evaluation of quality, citations, extraction accuracy or tool behavior;
- changes to embeddings or vector indexes when switching embedding models;
- client downtime or feature limitation during migration;
- credential revocation and integration shutdown;
- provider-side data deletion or account closure evidence;
- continued access to audit records needed for contract, security or incident purposes;
- removal of provider names and claims from current client disclosures and architecture documents;
- dependencies embedded in code, infrastructure-as-code, SDKs, workflows and evaluation baselines.

25.2 Model substitution

A replacement model shall not be assumed equivalent because it has similar general capabilities. KOMGIS shall rerun the evaluations relevant to the intended purpose and risk, including retrieval faithfulness, citation behavior, structured output, prompt injection resistance, agent tool selection and human-review workflow where applicable.

25.3 Retirement evidence

The provider record shall be moved to Retired only after active integrations are disabled, production credentials are revoked, data-return or deletion actions are addressed, current systems no longer route covered data to the provider and required records are preserved.

26. Vendor Register and Disclosure Record Management

The Vendor / Subprocessor Master Register and Model Provider Disclosure Records are controlled governance records. Records shall be accurate enough for KOMGIS to determine which provider services process which categories of data for which systems and clients.

26.1 Required master-register fields

- unique provider ID and provider legal name;
- service/product and provider category;
- provider owner and responsible technical contact;
- approval status, tier, approval date and next reassessment date;
- approved purposes and linked AI systems;
- data categories and data-subject categories where relevant;
- processing and storage regions;
- training/service-improvement position and retention summary;
- DPA/contract and subprocessor record references;
- client-specific restrictions and disclosure status;
- material conditions, compensating controls and residual risk;
- evidence location, last verification date and change history.

26.2 Version and change history

Provider records shall preserve material changes, including previous status, changed fields, effective date, reason and approver. Minor editorial corrections may be recorded through normal document version control. Material changes affecting provider approval or client disclosure shall have a dated change record.

26.3 Source of truth

KOMGIS shall identify one controlled source of truth for current approval status. Project documentation may reference or export the register but shall not create conflicting independent approval lists. When a provider is suspended or blocked, the source of truth must be updated promptly and operational owners informed.

27. Exceptions, Nonconformities and Corrective Action

An exception is a documented, time-bound authorization to deviate from a requirement in this document. A nonconformity is an unapproved failure to meet the requirement. Business urgency, provider popularity or developer preference is not itself an exception.

27.1 Exception record

- requirement from which deviation is requested;
- provider, service, systems and clients affected;
- business reason and time period;
- data categories and maximum processing scope;
- risk created by the deviation and compensating controls;
- prohibited activities or data while the exception is active;
- owner, approver and expiry date;
- exit, remediation or reassessment action.

27.2 Provider-governance nonconformities

Examples include client data sent to an unapproved AI tool, inaccurate claims about provider training or retention, use of a provider outside the approved region, failure to disclose a required subprocessor, expired conditional approval, untracked provider routing, or continued processing after suspension. KOMGIS shall contain the issue, assess affected systems and data, identify causes, implement corrective action and verify effectiveness.

28. Review and Enforcement

This document shall be reviewed at least annually and additionally when KOMGIS introduces a materially new AI provider category, experiences a material provider incident, changes its provider-governance method, receives significant client or audit findings, or relevant legal, contractual, security or industry requirements change.

- Unapproved public AI tools and personal AI accounts shall not be used for client confidential data.
- Developers shall not bypass provider approval by calling an alternate endpoint, personal account, reseller, gateway or region.
- A provider record with expired conditional approval shall be treated as pending unless renewed through the approved review process.
- Materially inaccurate client disclosure shall be corrected and escalated according to impact.
- Violations may result in provider suspension, removal of tool access, corrective training, project escalation or other action consistent with KOMGIS policies and contractual arrangements.

Good-faith reporting

Personnel shall promptly report suspected unapproved provider use, unexpected data exposure, incorrect provider routing or materially inaccurate provider claims. Provider concerns shall not be hidden or dismissed solely because the provider is widely used or described as enterprise-grade.

Appendix A. Provider Approval Tiers and Risk Matrix

The provider tier is based on the most consequential reasonably foreseeable processing scenario for the approved use, not the provider's general reputation. The provider owner may assign a higher tier where uncertainty is material.

Factor	Tier 3 - Limited	Tier 2 - Material	Tier 1 - Critical / high exposure
Data	Public or non-sensitive; no client data	Confidential client data or ordinary personal data	Sensitive/regulated data; large scale; broad source libraries; significant derived data
Provider role	Non-critical support tool	Material processor in business workflow	Core model, cloud or data infrastructure; failure affects multiple systems or clients
Access / actions	No production tool access	Read access or reversible integration	Write actions, privileged integration or broad system access
Retention	No covered data or minimal transient metadata	Defined provider retention with enterprise controls	Longer retention, complex exceptions, backups, full-content logs or unclear deletion
Region / transfer	No residency requirement	Known processing regions and manageable transfer requirements	Strict client residency, sensitive cross-border transfer or region ambiguity
Subprocessors	No material processing chain	Documented subprocessor chain	Complex gateway/model/cloud chain or concentration risk
Continuity	Easy manual replacement	Moderate migration effort	Major dependency, model revalidation, index rebuild or client outage risk
Client impact	Minimal	Business workflow or client-facing impact	Material contractual, privacy, legal, safety or fundamental-rights impact

Provider risk scoring

Where a numeric score is useful, KOMGIS may rate impact and likelihood from 1 to 5 and calculate an inherent risk score before controls and residual score after controls. Numeric scoring supports consistent review but does not replace judgment or mandatory blocking rules.

Score	Impact guidance	Likelihood guidance
1	Negligible operational effect; no meaningful client or data impact	Rare; requires exceptional conditions
2	Minor rework or limited non-sensitive exposure	Unlikely but plausible
3	Client dissatisfaction, material rework, limited confidentiality or privacy impact	Possible under foreseeable conditions
4	Serious contractual, privacy, security or business impact; multiple affected users/records	Likely without effective controls or known recurring issue
5	Severe or large-scale exposure, serious harm, critical service failure or major regulatory risk	Expected or already occurring under the planned design

Residual score	Risk position

Residual score	Risk position
1-4	Low - provider owner may approve within delegated authority.
5-9	Moderate - documented controls and owner acceptance required.
10-15	High - formal security/privacy and governance review; management or delegated high-risk approval.
16-25	Critical - do not deploy until executive, technical, security/privacy and legal/compliance review as applicable; prohibited uses remain prohibited.

Appendix B. Vendor / Subprocessor Master Register

The following tables define the minimum register structure. Provider names are intentionally blank because the source KOMGIS policy does not identify which vendors are currently contracted or approved. Authorized owners shall populate these records from verified current evidence before controlled release or client disclosure.

B.1 Current production providers and subprocessors

ID	Provider / legal entity	Service / role	Approved purpose / systems	Data categories	Region(s)	Training / retention summary	Tier / status	Owner / next review
[V-001]	[Provider legal name]	[Product and processing role]	[Use case and linked system IDs]	[Data categories]	[Processing/storage region]	[Verified training and retention position]	[Tier / Approved]	[Owner / YYYY-MM-DD]
[V-002]	[Provider legal name]	[Product and processing role]	[Use case and linked system IDs]	[Data categories]	[Processing/storage region]	[Verified training and retention position]	[Tier / Approved]	[Owner / YYYY-MM-DD]
[V-003]	[Provider legal name]	[Product and processing role]	[Use case and linked system IDs]	[Data categories]	[Processing/storage region]	[Verified training and retention position]	[Tier / Approved]	[Owner / YYYY-MM-DD]

B.2 Conditionally approved or pilot providers

ID	Provider / service	Permitted pilot scope	Prohibited data / use	Conditions / remediation	Expiry date	Owner
[P-001]	[Provider / product]	[Synthetic/public data, named test system]	[Client data, personal data, production use]	[Evidence or control required before full approval]	[YYYY-MM-DD]	[Name / role]
[P-002]	[Provider / product]	[Scope]	[Restrictions]	[Conditions]	[YYYY-MM-DD]	[Name / role]

B.3 Suspended, blocked and retired providers

ID	Provider / service	Status	Effective date	Reason	Required operational action	Evidence / record owner
[R-001]	[Provider / product]	[Suspended / Blocked / Retired]	[YYYY-MM-DD]	[Incident, contract change, data term, exit or other]	[Disable routing, revoke credentials, migrate, delete data]	[Reference / owner]
[R-002]	[Provider / product]	[Status]	[YYYY-MM-DD]	[Reason]	[Action]	[Reference / owner]

B.4 Master register completion rules

- Use the provider legal entity or contracting entity where known; record the commercial brand separately when different.

- Identify the exact service or product, not only the parent company.
- Link approved purposes to AI System Inventory IDs or controlled project records.
- Summarize provider training and retention only from verified terms and configuration; keep detailed evidence in the provider disclosure record.
- Record client-specific restrictions in the detailed provider record even when the master register shows general approval.
- Do not delete historical blocked, suspended or retired entries needed to explain prior processing; move them to the appropriate status table and preserve change history.

Appendix C. Model Provider Disclosure Record

Complete one record for each material model-provider service path. Separate records may be required when the same provider is used through materially different products, regions, plans or managed platforms.

Field	Record
Disclosure record ID	[MPD-___]
Provider legal name / contracting entity	[ ]
Commercial provider / brand	[ ]
Service, API or managed platform	[ ]
Approved model family / identifiers	[ ]
Provider owner	[ ]
Technical owner(s)	[ ]
Linked AI System Inventory IDs	[ ]
Approval status / tier	[ ]
Initial approval date / next reassessment	[ ]

C.1 Intended processing

Question	Record
What exact business purpose requires the provider?	[ ]
Which KOMGIS or client systems call the provider?	[ ]
Which API endpoint, cloud region or deployment path is used?	[ ]
Are requests routed through a gateway or other vendor?	[ ]
Which input modalities are used?	[Text / files / images / audio / video / structured data / other]
Which data categories are sent?	[ ]
Which identifiers or metadata are included?	[ ]
Which outputs or derived data are returned and stored by KOMGIS?	[ ]

Question	Record
Does the provider receive retrieved RAG chunks or source citations?	[ ]

C.2 Provider data-use position

Topic	Verified position	Evidence / configuration
Prompt / input training use	[Yes / No / Unclear]	[Term, plan, URL reference or contract section]
Output training use	[Yes / No / Unclear]	[ ]
Service-improvement use	[Describe]	[ ]
Human content review	[Describe / none known]	[ ]
Opt-out / enterprise exclusion	[Enabled / N/A / required]	[Owner, setting and verification date]
Fine-tuning dataset use	[N/A or approved scope]	[Client approval and dataset record]

C.3 Retention and deletion

Data / feature	Retention	Deletion method / exception
API request / response content	[ ]	[ ]
Uploaded files	[ ]	[ ]
Batch processing	[ ]	[ ]
Provider safety / abuse logs	[ ]	[ ]
Provider dashboards / playgrounds	[ ]	[ ]
Fine-tuning data / model artifacts	[ ]	[ ]
Support records / diagnostic snapshots	[ ]	[ ]
Backups, if documented	[ ]	[ ]

C.4 Processing region and subprocessors

Field	Record
Configured inference processing region	[ ]
Storage region for retained content	[ ]
Support or administrative access regions	[ ]
Data residency commitment and limitations	[ ]
International transfer assessment reference	[ ]
Subprocessor list source and verification date	[ ]

Field	Record
Material subprocessors / processing roles	[ ]
Subprocessor change notification route	[ ]

C.5 Security and enterprise controls

Control	Implemented / evidence
Company-managed account and enterprise plan	[ ]
SSO / MFA / administrative access control	[ ]
Credential storage and rotation	[ ]
Project / workspace / environment isolation	[ ]
Regional endpoint configuration	[ ]
Private networking / egress restrictions where required	[ ]
Content logging disabled or restricted	[ ]
Provider audit / assurance evidence reviewed	[ ]
Security and incident contact route	[ ]
Fallback / disable / substitution mechanism	[ ]

C.6 Approval

Approval field	Record
Inherent provider risk	[Score / narrative]
KOMGIS controls / compensating controls	[ ]
Residual provider risk	[Score / narrative]
Client-specific restrictions	[ ]
Approval conditions	[ ]
Approved by / role / date	[ ]
Security/privacy review by / date	[ ]
Legal/compliance review, where required	[ ]
Next reassessment date	[ ]

Appendix D. Provider Due Diligence Questionnaire

The provider owner shall complete or obtain answers appropriate to the provider tier. Evidence may come from contract documents, DPA, provider security documentation, service configuration, formal questionnaire responses or other authoritative provider material.

D.1 Provider identity and service

Question	Response	Evidence
What legal entity provides and contracts for the service?	[Answer]	[Evidence / owner / date]
Which specific product, API, endpoint, model family and plan will KOMGIS use?	[Answer]	[Evidence / owner / date]
Is the service generally available, preview, beta or experimental?	[Answer]	[Evidence / owner / date]
Does another gateway, marketplace or reseller process the request?	[Answer]	[Evidence / owner / date]

D.2 Data processing

Question	Response	Evidence
What content, metadata and identifiers does the service receive?	[Answer]	[Evidence / owner / date]
Does the service receive source files, RAG chunks, embeddings or tool payloads?	[Answer]	[Evidence / owner / date]
What derived data or logs does the provider create?	[Answer]	[Evidence / owner / date]
Can provider personnel access content and under what conditions?	[Answer]	[Evidence / owner / date]

D.3 Training and data use

Question	Response	Evidence
Can inputs be used to train provider or third-party models?	[Answer]	[Evidence / owner / date]
Can outputs be used for training or quality improvement?	[Answer]	[Evidence / owner / date]
What enterprise opt-out or exclusion applies?	[Answer]	[Evidence / owner / date]
Are there separate terms for files, batch, fine-tuning or preview features?	[Answer]	[Evidence / owner / date]

D.4 Retention and deletion

Question	Response	Evidence
How long are inputs and outputs retained?	[Answer]	[Evidence / owner / date]
Are safety or abuse logs retained under exceptions?	[Answer]	[Evidence / owner / date]
Is ZDR available and which features are excluded?	[Answer]	[Evidence / owner / date]
How are files, batch jobs, caches and support snapshots deleted?	[Answer]	[Evidence / owner / date]
What backup retention is documented?	[Answer]	[Evidence / owner / date]

D.5 Privacy and regions

Question	Response	Evidence
Which processing and storage regions apply to the exact service?	[Answer]	[Evidence / owner / date]
Can support or subprocessors access data from other regions?	[Answer]	[Evidence / owner / date]
Is a DPA available and applicable?	[Answer]	[Evidence / owner / date]
What transfer mechanism or regional commitment is documented where relevant?	[Answer]	[Evidence / owner / date]

D.6 Subprocessors

Question	Response	Evidence
Where is the current subprocessor list?	[Answer]	[Evidence / owner / date]
Which subprocessors may process covered content or metadata?	[Answer]	[Evidence / owner / date]
How are subprocessor changes communicated?	[Answer]	[Evidence / owner / date]
Does KOMGIS have a client notification or objection obligation?	[Answer]	[Evidence / owner / date]

D.7 Security

Question	Response	Evidence
What identity, MFA, SSO and administrator controls are available?	[Answer]	[Evidence / owner / date]
How are API credentials scoped and managed?	[Answer]	[Evidence / owner / date]
What encryption, audit logging and tenant isolation controls are documented?	[Answer]	[Evidence / owner / date]
What independent security assurance is available?	[Answer]	[Evidence / owner / date]
How does the provider handle vulnerabilities and incidents?	[Answer]	[Evidence / owner / date]

D.8 Resilience and lifecycle

Question	Response	Evidence
What rate limits, quotas and availability constraints apply?	[Answer]	[Evidence / owner / date]
How are model versions changed or deprecated?	[Answer]	[Evidence / owner / date]
Can KOMGIS pin model versions?	[Answer]	[Evidence / owner / date]
What notice is given for service retirement?	[Answer]	[Evidence / owner / date]
What data export or portability options exist?	[Answer]	[Evidence / owner / date]

D.9 Client and contract

Question	Response	Evidence
Do client contracts restrict named providers, regions or data categories?	[Answer]	[Evidence / owner / date]
Is client approval required before adding this subprocessor?	[Answer]	[Evidence / owner / date]
What disclosure must KOMGIS provide?	[Answer]	[Evidence / owner / date]
Are there confidentiality or retention terms stricter than the provider default?	[Answer]	[Evidence / owner / date]

D.10 KOMGIS architecture

Question	Response	Evidence
What data can KOMGIS remove, tokenize or minimize before sending?	[Answer]	[Evidence / owner / date]
Can logging be limited to metadata?	[Answer]	[Evidence / owner / date]
Can the provider be isolated per client, project or environment?	[Answer]	[Evidence / owner / date]
What is the fallback if the provider is suspended?	[Answer]	[Evidence / owner / date]
How will KOMGIS verify deletion and revoke credentials at exit?	[Answer]	[Evidence / owner / date]

Appendix E. Provider Approval Checklist

#	Review item	Complete / Evidence
1	Provider legal entity, service, model/product and provider owner are identified.	☐ _____
2	The business purpose and linked AI systems are documented.	☐ _____
3	The exact processing path, gateway and endpoint/region are documented.	☐ _____
4	Data categories, identifiers, RAG content, files and derived data are mapped.	☐ _____
5	Provider risk tier and inherent risk are assigned.	☐ _____
6	Provider training and model-improvement terms are verified for the exact service and plan.	☐ _____
7	Service-improvement and human-review uses are assessed.	☐ _____
8	Retention is documented separately for request content, files, batch features, logs and support records as applicable.	☐ _____
9	ZDR or other retention controls are verified and feature exceptions are recorded.	☐ _____
10	Deletion method and source/derived data linkage are documented.	☐ _____
11	Processing and storage regions are documented and configured.	☐ _____
12	Client data-residency restrictions are captured.	☐ _____
13	DPA, transfer and privacy review are completed where applicable.	☐ _____
14	Subprocessor list, processing roles and change process are recorded.	☐ _____

#	Review item	Complete / Evidence
15	Security documentation and enterprise controls are reviewed proportionate to risk.	☐ _____
16	Company-managed accounts, MFA/SSO and least-privilege administration are configured where available and required.	☐ _____
17	API credentials are stored securely, scoped and separated by environment/client where required.	☐ _____
18	Content logging and observability exposure are minimized and retention is defined.	☐ _____
19	Provider is not relied upon to enforce KOMGIS tenant or object authorization.	☐ _____
20	RAG/vector provider filters and client isolation have been tested where applicable.	☐ _____
21	Agent tool read/write scopes and human approval requirements are documented where applicable.	☐ _____
22	Client contract restrictions and provider approval requirements are reviewed.	☐ _____
23	Client-facing provider/subprocessor disclosure is prepared where required.	☐ _____
24	Technical pilot or integration test has passed the defined acceptance criteria.	☐ _____
25	Fallback, disable, suspension and substitution paths are defined.	☐ _____
26	Residual risk and approval conditions are documented.	☐ _____
27	Required security/privacy/legal/compliance approvers have signed or recorded approval.	☐ _____
28	Next reassessment date and monitoring owner are assigned.	☐ _____

Appendix F. Change and Reassessment Trigger Matrix

Trigger event	Immediate question	Minimum review action
New provider or model family	Will new client or confidential data leave KOMGIS control?	Create provider record; map data; assign tier; complete approval before production.
New product feature	Does the feature have different terms, retention, logs or subprocessors?	Review feature-specific terms and configuration; update retention and data map.
Model alias or version change	Can behavior, tool use, structured output or evaluation performance change?	Run impact assessment and relevant regression evaluation; update model record.
New processing region	Does client residency or transfer position change?	Review region, DPA/transfer, support access and client commitments.
Subprocessor addition	Can the new party process covered content or metadata?	Assess role and region; update register; perform required client notice or objection process.
Training/data-use term change	Can provider use content in a new way?	Suspend affected data if necessary; review terms; update approval and client disclosure.
Retention change	Does provider retain more content or lose ZDR coverage?	Assess client and privacy impact; reconfigure, reduce data or select another service.
Security incident	Could KOMGIS or client data, credentials or service integrity be affected?	Invoke incident process; contain; preserve evidence; contact provider; reassess approval.
Material outage / instability	Can workflow fail unsafe, duplicate actions or bypass approval?	Use approved fallback; review retries and failure behavior; update continuity controls.

Trigger event	Immediate question	Minimum review action
New AI agent write scope	Can the provider execute external or difficult-to-reverse actions?	Review tool scopes, credentials, human approval and action logging.
New client contract restriction	Is an existing approved provider prohibited or approval-gated for the client?	Record client restriction and enforce provider routing or deployment separation.
Higher-sensitivity data	Will the provider receive sensitive or regulated data not covered by approval?	Re-tier provider and system; perform enhanced privacy/security/legal review before use.
Provider acquisition / legal entity change	Do contracts, terms, regions or subprocessors change?	Review contracting entity and applicable terms; update register and disclosure.
Provider retirement	Are systems, credentials or client disclosures still dependent on the service?	Execute exit plan; migrate; revoke; address deletion; mark retired.

Appendix G. Client-Facing Subprocessor Disclosure Template

Controlled client-facing extract

This appendix is a template. Populate it only with providers that actually process the specific client service. Verify each material statement against the internal provider record before issue.

KOMGIS uses selected third-party service providers to operate and support the contracted service. These providers are approved for defined purposes and are subject to KOMGIS provider-governance, security and data-processing review. The applicable list depends on the client solution and deployment architecture.

Provider	Service role and processing purpose	Data categories	Processing region / location information	AI training position, where relevant	Effective date
[Provider name]	[AI inference / cloud hosting / managed database / vector search / monitoring / integration] - [plain-language purpose]	[High-level categories]	[Verified region information]	[Verified position for the approved service]	[YYYY-MM-DD]
[Provider name]	[Role and purpose]	[Categories]	[Region information]	[Training position or N/A]	[YYYY-MM-DD]
[Provider name]	[Role and purpose]	[Categories]	[Region information]	[Training position or N/A]	[YYYY-MM-DD]

G.1 Suggested disclosure notes

- KOMGIS does not use client data to train or fine-tune KOMGIS or third-party models unless the client explicitly approves the defined use and safeguards.
- Provider services are approved for defined purposes and data categories. KOMGIS may restrict a generally approved provider for a specific client because of contractual, regulatory or data-residency requirements.
- Where the contract requires advance notice of a material subprocessor change, KOMGIS will use the agreed notification route and timing.
- Questions about the providers applicable to a specific KOMGIS service should be directed through the client's agreed KOMGIS contact or governance/security review process.

G.2 Change notice template

Subject: Notice of material provider / subprocessor change

KOMGIS plans to [add / replace / materially change] [provider or service name] for [service purpose]. The change is expected to take effect on [date]. The provider will process [high-level data categories] in connection with [client service / feature]. The documented processing region is [region information]. [Where relevant: client content is not approved for provider model training under the applicable service terms and configuration.]

This change has been reviewed through KOMGIS's provider-governance process. [Client action required / No client action required under the current agreement]. Questions or contractual objections should be submitted through [agreed route] by [date, where applicable].

Appendix H. Minimum Evidence Pack and Record Retention

The provider owner shall maintain evidence proportionate to the provider tier. Evidence should be dated or versioned so that KOMGIS can identify what was reviewed when a provider was approved or reassessed.

Evidence item	Tier 3	Tier 2	Tier 1 / critical
Provider identity and service description	Required	Required	Required
Approved purpose and linked systems	Required	Required	Required
Data-flow and category record	Basic / as applicable	Required	Formal and linked to Data Processing Map
Training / data-use terms evidence	If AI or content processor	Required	Formal; configuration evidence
Retention and deletion evidence	As applicable	Required	Formal; feature exceptions documented
Region and residency evidence	As applicable	Required	Formal; client restrictions mapped
DPA / privacy review	If personal data	Required where applicable	Formal where applicable
Subprocessor list and change process	As applicable	Required	Formal and monitored
Security documentation review	Basic	Required	Enhanced / formal
Technical configuration evidence	Basic	Required	Formal; critical settings independently verified where practical
Client contract / disclosure review	As applicable	Required	Formal
Pilot / technical validation	Basic	Required	Formal and linked to system evaluation
Residual risk acceptance	Basic	Documented	Formal approval
Exit / substitution plan	Optional if trivial	As applicable	Required
Annual / trigger reassessment	Periodic	Required	Required and enhanced by risk

H.1 Suggested evidence references

- executed contract, order form and applicable service terms;
- DPA and transfer-related documentation where relevant;
- provider privacy, enterprise data-use, retention and deletion documentation;
- subprocessor list and change-notification subscription or control;
- security documentation, assurance report summary or completed security questionnaire as appropriate;
- screenshots or configuration exports for material settings such as region, retention, SSO or logging;

- architecture and Data Processing Map references;
- AI System Inventory references and model identifiers;
- evaluation, security test and client-isolation evidence;
- approval and residual-risk acceptance record;
- material change, incident, suspension and retirement records.

H.2 Record retention

Current provider approval records shall be retained while the provider remains active. Superseded approval records, material change records, suspension or incident evidence and retirement records shall be retained according to KOMGIS contractual, legal, security and audit requirements. Provider records containing confidential contract or security information shall be access restricted and shall not be included wholesale in public or client-facing disclosures.

Reference Documents

- KOMGIS Responsible AI and AI Management Policy - company-wide governance requirements for AI systems, including provider, vendor and subprocessor governance.
- KOMGIS Data Privacy Policy - client data, AI inputs and outputs, embeddings, providers, retention, deletion and data requests.
- KOMGIS AI Security Policy - access control, prompt injection, RAG, agent tools, secrets, output security and secure development.
- KOMGIS AI Incident Response Plan - severity, containment, investigation, communication, corrective action and reactivation for AI incidents.
- KOMGIS AI System Inventory - system ownership, intended use, models, data, risk and operational status.
- KOMGIS AI Risk Assessment / Impact Assessment - known and foreseeable risks, affected parties, controls and residual risk.
- ISO/IEC 42001:2023 - Artificial intelligence management system framework, used as a management-system reference.
- Regulation (EU) 2024/1689 - EU Artificial Intelligence Act, subject to system-specific role and applicability analysis.

Provider interpretation, contractual and legal questions shall be escalated to AI Governance / Technical Leadership and, where legal, privacy or regulatory interpretation is required, to qualified legal or compliance review.